

Florence: Architecture - Row Level Security (RLS) Access Matrix

The following document details the database access matrix based on the established Row Level Security policies. Access levels are categorised by operations (All for create, read, update and delete; Read for select; Update for update; None for no access) and their scopes (Own, Assigned or Global).

Role and Scope Definitions

- **Admin:** Authorised users with the administrator role claim in their JSON Web Token metadata.
- **Clinician:** Healthcare professionals with a matching entry in the clinician profiles table. The assigned scope means the patient record is directly linked to the clinician identifier.
- **Patient:** Users with a matching entry in the patient profiles table. The own scope means the record is tied directly to the identifier of the authenticated user.
- **Service Role:** Backend system services that bypass standard Row Level Security policies.

Access Matrix Overview

Table Name	Admin	Clinician	Patient
User and Profile Management			
admin_profiles	All	None	None
clinician_profiles	All	Read/Update (Own)	None
patient_profiles	All	Read/Update (Assigned)	Read/Update (Own)
user_settings	All (Own)	All (Own)	All (Own)

Table Name	Admin	Clinician	Patient
Dictionaries and Global Data			
organisations	All	Read (Global)	Read (Global)
medication_dictionary	All	Read (Global)	Read (Global)
dosage_frequencies	All	Read (Global)	Read (Global)
Clinical Patient Data			
patient_medications	All	All (Assigned)	All (Own)
disease_logs	All	All (Assigned)	All (Own)
patient_thresholds	All	All (Assigned)	Read (Own)
clinical_documents	None	Read (Assigned)	All (Own)
clinician_notes	All	Read/Delete (Own), Create (Assigned)*	None
patient_recommendations	All	Read (Assigned)	All (Own)
automated_actions	None	Read (Assigned)	All (Own)
Patient Logs and Monitoring			
daily_patient_logs	All	Read (Assigned)	All (Own)
medication_intake_logs	All	Read (Assigned)	All (Own)
patient_monitor_data	All	Read (Assigned)	All (Own)
patient_activity_logs	All	Read (Assigned)	All (Own)
patient_chat_history	None	Read (Assigned)	All (Own)
Storage Buckets (Files)			
Bucket (Profile Pictures)	None	None	All (Own via auth.uid)
clinical-documents	None	Read (Assigned)	All (Own via auth.uid)
meal_photos	None	None	None

Note: Clinician note updates require both Own and Assigned scopes to be true simultaneously.

Detailed Access Breakdown by Role

Administrator Role

Administrators operate as overarching system maintainers. They possess full administrative access to almost all tables, allowing them to manage organisations, medical dictionaries, user profiles and all telemetry data across the entire database. Due to strict policy definitions, administrators lack explicit access rights for clinical documents, automated actions and patient chat history. If an administrator attempts to access these specific tables through the standard application programming interface, the database will deny the request.

Clinician Role

Clinicians primarily operate on a relationship basis, largely interacting with data belonging to patients explicitly assigned to them. Clinicians hold full rights to create, update and delete disease logs, patient medications, and patient thresholds for their assigned patients. For clinician notes, their access is split: they may only create notes for currently assigned patients, but they retain read and delete access exclusively for notes they personally authored (Own scope), retaining this access even if the patient is subsequently transferred to another clinician. Updating an existing note requires both conditions to be met: the clinician must be the author and the patient must still be assigned to them. They can update their assigned patient profiles as well as their own clinician profiles. The system restricts clinicians to read-only access for a patient's historical records. This read-only scope covers daily patient logs, medication intake logs, patient activity logs, patient chat history, patient monitor data, clinical documents, automated actions and patient recommendations. Furthermore, clinicians possess global read access for viewing organisations and standard medical dictionaries.

Patient Role

Patients maintain extensive control over their self-reported information but face strict restrictions regarding clinical baselines set by medical professionals. Patients can fully manage their own clinical documents, daily patient logs, patient activity logs, medication intake logs, patient monitor data, disease logs, patient medications, patient chat history, automated actions and patient recommendations. They are permitted to update their personal information in the patient profiles table and modify their preferences in the user settings table. While patients can view the clinical parameters established by their doctors in the patient thresholds table, they cannot modify them. The security policies explicitly prevent patients from viewing clinician notes or any administrative profiles.